

Raising Atlantic — Platform Details for Legal Drafting

Purpose. This document is a factual, code-grounded reference for drafting the platform's legal instruments: **Privacy Policy / POPIA notice, Terms of Use / Terms of Service, EULA, Cookie Policy, Data Processing Agreements, and a Records-of-Processing / data inventory**. It describes what the codebase *actually does today*, what it is *designed to do*, and the **gaps** that must be closed (or accurately disclosed) before the legal documents can be both truthful and compliant.

Audience. The drafting attorney / privacy counsel, and the engineering team responsible for closing the compliance gaps. It is written so a non-engineer can use it.

Generated: 2026-06-26. Reflects branch `feat/pedichack-feature-requests`. This is a snapshot — re-verify before signing anything, because the repository is mid-migration (see §2).

! 0. The one thing the drafter must understand first

The platform is at a pre-launch / prototype stage. The compliant architecture is largely *designed but not yet deployed or enforced*. Several controls described in the codebase's own engineering policy (`CLAUDE.md`) and in marketing copy are *not implemented in code today*.

Concretely, as of this snapshot, the following are NOT operational (details in §8–§12):

Control commonly assumed in a healthtech privacy policy	Reality in code today
User authentication (login actually checks credentials)	Not implemented — auth guard is a no-op stub that returns <code>true</code> for everyone
Role-based access control enforced	Broken / fails open — guard allows the request when no user is present (always)
Tenant isolation (a clinic can't see another clinic's data)	Not enforced — tenant scoping is an optional client-supplied query param
Parental consent recorded before a child record is created	Not implemented in API/web (a consent <i>modal</i> exists in mobile only, stored locally)
Data stored in South Africa	No — production prototype DB is Neon in the EU/US today
Special-category fields (medical conditions, HPCSA/SANC) encrypted	No — stored in plaintext; field encryption is a deferred future phase
"Soft delete then 30-day grace" retention	Not implemented — delete paths do an immediate hard delete
Data Subject Access / export / erasure endpoints	Not implemented in the API (mobile has UI that only writes a local request marker)

Implication for drafting: the legal documents must either (a) be written against the **intended/target** architecture *with an honest "current state" framing*, or (b) wait until the controls are built. They must **not** assert that controls are operational when they are not — that itself is a POPIA "openness" (Condition 6) and a Consumer Protection Act misrepresentation risk. Wherever this document says **PLANNED** or **MISSING**, do not let the policy claim it as live.

1. Who the responsible party is — and an identity problem to resolve

POPIA requires the **"responsible party"** (the entity that determines why and how personal information is processed) to be named, with an **Information Officer** registered with the Information Regulator. The codebase currently uses **three different names** across surfaces, which the legal team must reconcile into a single contracting entity:

Name used	Where it appears	Contact email shown
Raising Atlantic	Main web app legal pages, API domain, repo	<code>legal@raisingatlantic.com</code>
Atlantic Children's Practice (ACP)	PediCheck privacy/terms pages, PediCheck paid plan	<code>hello@pedichack.co.za</code>
PediCheck	PediCheck product/landing brand	<code>hello@pedichack.co.za</code>

Action for legal: Decide the single registered responsible party (and whether ACP and Raising Atlantic are the same legal entity, a parent/subsidiary, or a practice + tech vendor relationship). This matters because:

- If a **registered medical practice** (ACP) is the controller of clinical records, the **National Health Act** and **HPCSA** record-keeping/confidentiality rules attach to it directly.

- If the **tech company** (Raising Atlantic) merely processes on the practice's behalf, it is an **operator** under POPIA s1/s20–21 and needs an **operator agreement** with the practice — not a controller-style privacy policy.
- The **Information Officer** must be appointed and registered for whichever entity is the responsible party.

2. Current state vs. target state (the migration caveat)

The repository is mid-migration between two stacks. The legal documents must state which stack is live at the **date of signing**, because the cross-border (POPIA s72) exposure differs materially:

Layer	Current / prototype (LIVE today)	Target (DESIGNED, ADR-approved, NOT yet deployed)
API hosting	Vercel serverless + local	GCP Cloud Run, <code>africa-south1</code>
Web hosting	Vercel (EU edge)	GCP Cloud Run <code>africa-south1</code> ; Vercel kept marketing-only
Database	Neon Postgres (EU <code>eu-central-1</code> / US <code>us-east-2</code>)	Cloud SQL Postgres 15 , <code>africa-south1</code> , private IP only
Lead/marketing data	Google Sheets (Google global)	(same — marketing data only)
Error tracking	Sentry (US ingest), gated on DSN	(same)
Infra (Terraform)	Committed but commented-out / undeclared	Full GCP build in <code>africa-south1</code>

The entire GCP/ `africa-south1` Terraform (Cloud SQL, Cloud Run, VPC, Secret Manager, log sink, monitoring) is **committed but disabled** — resource blocks are commented out and CI/CD pipelines are gated behind a Workload Identity secret that has not been set. **Nothing is deployed to GCP yet.**

Reference: `docs/adr/0001-hosting.md` , `docs/VERCEL_PORTABILITY.md` , `infra/envs/{dev,staging,prod}/main.tf` , `src/apps/api/.env.example` , `TODO_GCP.md` .

3. The products (what the legal documents must cover)

The monorepo (`src/apps/`) contains four front-ends plus one API:

1. **web** — Next.js 16 / React 19 main application (parents + clinicians + admin). Patient/child records, growth, vaccinations, milestones, appointments, reports, clinician verification, signup/login, marketing landing + pricing. *Currently runs auth and child data on a browser-local mock layer (`localStorage`); switches to the live API via `NEXT_PUBLIC_USE_API=true` .*
2. **mobile** — Expo / React Native app (parents + clinicians + admin). Mirrors the web data model. Contains the most mature consent and POPIA-rights UI (see §11), but it currently writes those to local device storage, not the server. Auth is a fixture/mock.
3. **pedicheck** — Next.js marketing/landing site for the "PediCheck" product (a paediatric symptom-triage
 - waitlist offering, "launching September 2026"). Collects waitlist/contact/feature-request data into **Google Sheets**. Has the most developed (but self-labelled placeholder) legal pages.
4. **ops** — Next.js scaffold; **unmodified create-next-app template, no data collection**. Ignore for legal purposes until it does something.
5. **api** — NestJS 11 + TypeORM + PostgreSQL backend. The system of record for all clinical data.

4. Personal information inventory (the data dictionary)

This is the complete inventory of personal data the platform **models and stores**, classified under POPIA. Database entities are defined in `*.model.ts` files under `src/apps/api/src/` (verified against the initial SQL migration `src/apps/api/db/migrations/1777901196470-InitialSchema.ts` — **16 tables**). Shared domain types mirror these in `src/pkgs/types/src/` .

POPIA classes used below:

- **PI** = ordinary *personal information* (s1).
- **SPI** = *special personal information* (s26) — here, **health** data.
- **Child** = personal information of a **child** (a person under 18, s1) — POPIA s34–35 prohibits processing except on specific grounds (notably consent of a competent person — the parent/guardian). The product's core data is children's health data, i.e. **SPI about a child** — the most protected category POPIA has.

4.1 Adults — account holders

User → **users** (`src/apps/api/src/users/users.model.ts`) — holds parents, clinicians, and admins: `title` , `name` (PI), `email` (PI, unique), `phone` (PI), `imageUrl` (PI — photo), `role` (`parent` / `clinician` / `admin` / `super_admin`), `timestamps`.

No password / credential column exists — authentication is not yet modelled (see §8).

ClinicianProfile → **clinician_profiles** (`.../users/clinician-profile.model.ts`): `specialty` , `bio` (free text). 1:1 with **User** ; many-to-many with **Practice** .

HPCSA / SANC professional-registration numbers are NOT stored anywhere in the database. They appear only in mobile UI fixtures (TODO), the log-redaction allow-list, and seed prose. The web clinician signup form *collects* an "HPCSA/PMC license number" but there is no column to persist it and no verification record (see §8.5).

4.2 Children — the core special-category data

Child → **children** (`.../children/children.model.ts`): `name` , `firstName` , `lastName` , `gender` (`male` / `female`), `dateOfBirth` , `imageUrl` (photo), `notes` (free text — may contain health info), `progress` , `status` , FK to parent **User** and (optional) clinician **User** . **All of this is SPI about a child.**

Children have one-to-many health records, **all SPI about a minor**:

Entity → table	Sensitive fields	Notes
GrowthRecord → <code>growth_records</code>	<code>height</code> , <code>weight</code> , <code>headCircumference</code> , <code>date</code> , <code>notes</code>	Anthropometric health data. Percentiles are <i>computed</i> , not stored. Carries <code>PENDING_ASSESSMENT</code> status.
CompletedVaccination → <code>completed_vaccinations</code>	<code>vaccineId</code> (EPI), <code>dateAdministered</code> , <code>batchNumber</code> , <code>expiryDate</code> , <code>manufacturer</code> , <code>administeredByName</code> , <code>clinicName</code> , <code>source</code> (CLINICIAN/PARENT)	Immunisation record (SA DoH EPI schedule). <code>administeredByName</code> / <code>clinicName</code> are also third-party PI.
CompletedMilestone → <code>completed_milestones</code>	<code>milestoneId</code> , <code>dateAchieved</code> , <code>notes</code>	Developmental health.
Allergy → <code>allergies</code>	<code>allergen</code> , <code>severity</code> (mild/moderate/severe), <code>notes</code>	Health condition.
MedicalCondition → <code>medical_conditions</code>	<code>conditionName</code> , <code>diagnosisDate</code> , <code>notes</code>	Medical diagnosis. Flagged for future KMS encryption — currently plaintext.
Appointment → <code>appointments</code>	<code>scheduledAt</code> , <code>status</code> , <code>notes</code>	Links a minor to a medical visit.
Report → <code>reports</code>	<code>type</code> (CRECHE_ADMISSION/PROGRESS_REPORT/CLINICAL_SUMMARY), <code>content</code> (jsonb) , <code>pdfUrl</code>	The <code>content jsonb</code> can hold an arbitrary serialized snapshot of a child's clinical data — an unstructured SPI sink with no column-level protection. <code>pdfUrl</code> links to a generated child report.

4.3 Organisations (multi-tenancy)

Tenant → **tenants** : `org name` , `website` , `email` (PI), `phone` (PI), `logo`. Top of the multi-tenant hierarchy.

Practice → **practices** : `name` , `full address` / `city` / `state` / `zip` , `phone` (PI), `email` (PI), `website` , `latitude` / `longitude` (geolocation), `manager` (PI — named individual). For a solo practice, the practice record is effectively an individual's PI.

`practice_clinicians` — join table (FKs only).

4.4 Prospects / marketing (stored OUTSIDE the database)

These are captured by forms and written to **Google Sheets** (and, in the API path, also to the `system_logs` table and an admin email) — **not** to the clinical database. This is the data most actively flowing today, and the clearest cross-border (s72) item.

- Leads** (`.../leads/` , and `PediCheck api/leads/route.ts`): `email` (required), `name` , `phone` /WhatsApp number, `subject` , free-text `message` , `type` (`contact` / `waitlist`), `consent` (boolean), and the visitor's **IP address** (`x-forwarded-for`). The `PediCheck waitlist` packs the **child's age range** into the `message` field.
- Feature requests** (`.../feature-requests/`): `title` , `description` , optional `email` , `consent` (must be `true` if an email is supplied). Stored only in Google Sheets; the public list endpoint strips PII.

4.5 Operational / technical data

SystemLog → **system_logs** (../common/models/system-log.model.ts): type , message (text), metadata (jsonb), ipAddress , timestamp. **This table deliberately persists lead email + name in plaintext in metadata** for the contact flow — i.e. PII stored in the DB, readable via a currently **unguarded** GET /v1/system-logs (see §10).

BlogPost → **blog_posts** and **Example** → **examples** : CMS / scaffolding content — **no personal data**.

4.6 Summary — data categories by POPIA sensitivity

Category	Examples	Stored where	Encrypted at rest?
SPI — children's health (minors)	Child identity/DOB/photo; growth, vaccinations, milestones, allergies, conditions, appointments, reports	Postgres (clinical tables)	No (plaintext; KMS deferred)
PI — adults	Parent/clinician/admin name, email, phone, photo; practice/tenant contacts; manager name	Postgres	No
PI — prospects (marketing)	Lead email/name/phone/IP; child age range; feature-request email	Google Sheets + system_logs + admin email	No (and off-SA → s72)
Professional registration (HPCSA/SANC)	Collected on web clinician form	Not persisted (no column)	N/A
Parental consent for child data	Mandated by policy	Not modelled in API/web (mobile = local only)	N/A
Technical identifiers	UUIDs; IP addresses (system_logs.ipAddress)	Postgres	No (IP is PI)
Auth credentials	passwords/tokens	Not stored (no auth implemented)	N/A

5. Where the data physically lives (residency & hosting)

POPIA requires you to know and disclose where personal information is stored and who can access it.

Data	Current location (LIVE)	Target location	s72 transfer?
Clinical DB (children's health records)	Neon Postgres — EU eu-central-1 / US us-east-2	Cloud SQL africa-south1 (private IP, daily backup, 7-day PITR)	YES today ; eliminated after migration
Web/API hosting	Vercel (EU edge)	Cloud Run africa-south1	YES today for anything served via Vercel
Lead / feature-request data	Google Sheets (Google global)	(unchanged)	YES (consent-gated, marketing scope)
Error traces / session replay	Sentry (US ingest), if DSN set	(unchanged)	YES, if enabled
Telemetry (traces/metrics/logs)	GCP Cloud Trace/Monitoring/Logging africa-south1 (when enabled)	(unchanged)	No (in-region)

Encryption:

- **At rest:** relies on the **provider's default (Google-managed / Neon-managed) encryption** only. **Customer-managed keys (CMEK) are NOT configured** (commented TODO on the state bucket; unwired on the log bucket). **Field-level encryption of SPI (medical conditions, HPCSA/SANC) is NOT implemented** — a deferred post-launch item.
- **In transit:** TLS everywhere (Neon sslmode=require ; Cloud SQL designed ENCRYPTED_ONLY ; Vercel/LE TLS on custom domains). API sets HSTS via Helmet **only when NODE_ENV=production** .
- **No public storage buckets.** The only Terraform buckets (state, log archive) enforce no-public-access. No application upload/export bucket exists yet (so where child report PDFs / avatars will live is **not yet decided in infra** — flag).

References: docs/adr/0001-hosting.md , infra/modules/cloud-sql-postgres/ , infra/bootstrap/main.tf , infra/modules/log-sink/ , docs/adr/0003-app-security-baseline.md .

6. Third-party processors / operators & cross-border transfers (POPIA s72)

POPIA **s72** prohibits transferring personal information outside South Africa unless a lawful basis applies (adequate-protection recipient, binding agreement/SCCs, consent, or necessity for contract performance). Each external recipient that processes personal information on the platform's behalf is an **"operator"** (s1) and requires a **written operator agreement** (s20–21) ensuring security and instruction-only processing.

Cross-border / sub-processor register (the s72 list to put in the privacy notice):

Processor	Live?	Personal info it receives	Country	Lawful-basis / safeguard status
Google Sheets / Apps Script	YES (PediCheck + API leads)	email, phone/WhatsApp, child age range, message, IP	Google global (outside SA)	Consent-gated at submission; marketing data only; no DPA/SCC marked complete
Neon Postgres	YES (prototype)	entire clinical DB — children's health records	EU / US	No DPA signed ; eliminated by Cloud SQL migration
Vercel	YES	web/API hosting; lead-form PII transits	EU edge	No DPA marked complete
Sentry	If DSN set	error traces, request metadata, masked session replay	US (<code>ingest.sentry.io</code>)	Replay text masked; API redaction runs pre-send; no DPA/SCC complete
Google AI / Gemini (Genkit)	No (latent/configured)	none yet (would be prompt content if activated)	Google global	Assess before activating any AI feature
Stripe (payments)	No (ADR-decided, unbuilt)	payment + contact data; PCI scope SAQ-A (no card data on our servers)	US/EU	Plan SCCs when built
Ozow (payments, fast-follow)	No (planned)	EFT payment data	SA-domiciled	Avoids s72
Email/SMS provider	No (TBD)	recipient email/phone, message body	Depends — AWS SES <code>af-south-1</code> = SA; SendGrid/Twilio = US	Choose SA-region where possible
Cloudflare / BetterStack / PagerDuty / Slack	No (planned ops)	operational metadata, alerts	Global / non-SA	DPAs when adopted

In-country / no s72 concern: Cloud SQL `af-south1` (target), Cloud Run `af-south1` , GCP Trace/Monitoring/Logging/Secret Manager (`af-south1`), self-hosted fonts.

Bottom line for the privacy notice: today you must disclose **Google (Sheets), Neon (EU/US), Vercel (EU), and Sentry (US, if enabled)** as cross-border operators. After the GCP migration, the clinical DB transfer disappears and the disclosed list shrinks to Google Sheets (marketing) + Sentry (if used). **No operator DPA / SCC is recorded as signed for any of them yet** — this is an open compliance item (`docs/GO_LIVE/{COMPLIANCE,LEGAL}.md §4.3`).

Mitigant worth citing: the API has a comprehensive Pino **log-redaction** list (`src/apps/api/src/common/logging/redact-paths.ts`) covering email, names, phone, national/passport IDs, HPCSA/SANC, DOB, and medical fields, censored to `[REDACTED]` , and email is redacted in notification adapters. This runs **before** data would reach Sentry. (But note the leak paths in §10.)

7. Data collection points (every form that captures personal data)

#	App	Form / surface	Fields collected	Destination	Consent capture
1	pedicheck	Waitlist ("Founding 200")	email, WhatsApp number, child's age range	Google Sheets	<code>consent: true</code> sent; copy: "you agree to our privacy notice & to receive updates via email/WhatsApp"
2	pedicheck	Contact	email, subject (incl. "Privacy / data request (POPIA)"), message	Google Sheets	<code>consent: true</code> ; hard 400 if no consent

#	App	Form / surface	Fields collected	Destination	Consent capture
3	pedicheck	Feature request	title, description, email , explicit consent checkbox	Google Sheets	Explicit checkbox, required when email supplied
4	web	Homepage lead capture	email, message	NestJS POST /v1/leads (or mock)	None — <code>LeadData</code> has no consent field. Inconsistent with PediCheck.
5	web	Contact page	name, email, subject, message	Nowhere — <code>console.log no-op</code>	None. Copy implies processing that doesn't happen.
6	web	Member signup	full name, email, phone, relationship to patient, password	mock <code>localStorage</code> (or API)	Inline text only: "you agree to our terms and conditions" (no link, no checkbox)
7	web	Clinician signup	title, name, specialty, work email, HPCSA/PMC license number , password	mock <code>localStorage</code> (or API)	"credentials verified before access" notice
8	web	Child profile create/edit	first name, last name, DOB, gender, free-text notes, avatar upload, <code>parentId</code>	mock (or API)	"notes are confidential... shared with authorized clinicians if you choose" — no parental-consent gate
9	mobile	Child / growth / vaccination / milestone / messages / parent profile forms	child identity + full health record; parent display name, phone, language	local store (or API)	Parental consent modal (best in codebase, §11) but local-only, no age check, no policy link

8. Security & access control — implemented vs. missing (POPIA s19)

POPIA **Condition 7 (s19)** requires "appropriate, reasonable technical and organisational measures." Here is the honest state. **The application-layer input controls are good; the access-control layer is largely not yet built.**

8.1 Authentication — NOT IMPLEMENTED

- No `auth` module, no Passport strategy, no JWT issuance, no password storage, no hashing, no MFA.
- `JwtAuthGuard` (`src/apps/api/src/common/guards/jwt-auth.guard.ts`) is a placeholder that **always returns `true`** and never decodes a token or attaches a user.
- Web auth is a `localStorage` mock with **no password check**; mobile auth loads a hard-coded fixture user and mints an **unsigned** (`alg: "none"`) dev JWT the API ignores.
- Effect: every API endpoint is effectively public today.**

8.2 Authorisation / RBAC — PRESENT AS DECORATORS, FAILS OPEN

- `UserRole` enum exists (`parent` , `clinician` , `admin` , `super_admin`).
- `RolesGuard` (`.../common/guards/roles.guard.ts`) **returns `true` when no user is on the request** (which is always, since nothing authenticates) — it *fails open*. `@UseGuards(JwtAuthGuard, RolesGuard)` + `@Roles(...)` are therefore decorative.
- Several PII-exposing controllers have **no guards at all**: `users` (`GET /v1/users` returns all users with full PII), `feature-requests` , `leads` , `verifications` , `system-logs` , `master-data` , `examples` .
- The only global guard registered is the rate limiter.

8.3 Multi-tenant isolation — NOT A SECURITY BOUNDARY

- The `Tenant` → `Practice` → `Clinician` hierarchy exists as data, but tenant scoping is an **optional client-supplied** `?tenantId=` query param (`children.controller.ts`), not derived from an authenticated identity. A caller can pass any tenant id or omit it to read everything. **Cross-tenant access is fully possible.**

8.4 Input validation & CORS — IMPLEMENTED CORRECTLY

- Global `ValidationPipe` with `whitelist` , `forbidNonWhitelisted` , `transform.DTOs` use `class-validator` .
- CORS uses an **explicit allowlist in production** (no wildcard); `credentials: true` ; Helmet enabled with HSTS in prod. (Dev reflects any origin for device testing — intended, prod is locked.)

8.5 Clinician verification (HPCSA/SANC) — PARTIAL, KEY PIECES MISSING

- HPCSA/SANC numbers are **not stored** and there is **no regex validation** of their format.

- The `PENDING_ASSESSMENT` workflow is **read-only**: `/verifications` exposes two unguarded `GET` endpoints listing records awaiting review; there are **no approve/reject endpoints** (TODO phase-8). Parent-logged records cannot actually be clinician-verified yet.

8.6 Webhooks / payments — NONE EXIST

- No payment integration, no inbound webhooks, so no webhook-signature concern today.

8.7 What IS genuinely solid (defensible in the document)

Keyless **Workload Identity Federation** (no service-account JSON keys), no public buckets, private-IP DB *design*, prod deploys behind manual approval, branch protection (`enforce_admins`), image scanning (Trivy) + signing (Cosign) + SBOM in CI, **gitleaks** secret scanning, strict CORS, `class-validator` on all DTOs, `@nestjs/throttler` rate limiting. (Several of these are CI/app-layer and real; the *infra* controls remain undeployed.)

9. Consent

9.1 Parental consent for children's data (POPIA s35 / Children's Act) — MISSING in the system of record

- POPIA **s34–35** prohibits processing a child's personal information unless a competent person (parent/ guardian) consents (among other grounds). For **health** data this stacks with **s26–27** (special personal information).
- **There is no consent entity, column, or check** in the API or web. `ChildrenService.create()` saves a child with **no consent verification**; consent withdrawal is impossible because it is never recorded.
- The **mobile app** has a well-written `ParentalConsentModal` (names POPIA, "Special Personal Information," guardianship, right to withdraw/export/delete) **but** it (a) stores consent only in local device storage (`@ra/parental-consent`), (b) does **no age verification**, and (c) **does not link to a privacy policy / terms**.
- **Action**: build a server-side, audited parental-consent record (versioned, timestamped, withdrawable) that gates all child-record creation across web, mobile, and API.

9.2 Marketing consent — IMPLEMENTED (PediCheck only)

- PediCheck lead/feature-request flows enforce explicit `consent === true` (POPIA s11 / direct-marketing s69) before storing an email and before writing to Google Sheets.
- **The web app's lead form and contact form capture no consent** — inconsistent; reconcile.

10. Logging & PII handling

- **Good**: Pino is wired with a thorough redaction list (§6) covering all sensitive fields; notification adapters redact emails; redaction runs before Sentry.
- **Leak paths to fix (these bypass redaction)**:
 1. **PII persisted in the DB**: `leads.service.ts` writes lead **email + name** into `system_logs.message` and `system_logs.metadata` (jsonb) in **plaintext**, readable via the currently **unguarded** `GET /v1/system-logs` .
 2. **Full DTOs (with email/name/phone) sent to the error reporter / Sentry** in `users.service.ts` , `tenants.service.ts` , `examples.service.ts` (`reportException(error, { dto })`) — unredacted, and Sentry is off-SA (s72).
 3. `console.warn` in `RolesGuard` bypasses the Pino pipeline (no PII today, but an unredacted channel).

11. Data-subject rights & retention (POPIA s23–25, s14)

POPIA gives data subjects rights of **access** (s23), **correction/deletion** (s24), and participation (s23–25); **Condition 4 (s14)** governs retention and requires deletion/de-identification once the purpose is served (subject to other laws, e.g. National Health Act record-retention minimums).

Right / control	State in code
Data export / access (DSAR) endpoint	MISSING in API. Mobile has a "Request data export" button that writes a local <code>@ra/popia-requests</code> marker only. Copy promises a 30-day response.
Account / record deletion	MISSING as a compliant flow . <code>ChildrenService.remove()</code> / <code>UserService.remove()</code> do an immediate hard repo.remove() .

Right / control	State in code
Soft delete then 30-day grace	NOT implemented — <code>ARCHIVED</code> exists as an enum value but no <code>deletedAt</code> column, no transition-first logic, no scheduled hard-delete job. Mobile copy promises "soft-archived for 30 days, then permanently deleted."
Correction	Generic update endpoints exist, but unauthenticated.
Right to object / withdraw consent	No mechanism (consent isn't recorded).
Audit log of access/changes	PLANNED , not built.

Note the conflict the legal team must resolve: the **mobile UI already promises** a 30-day export response and a 30-day soft-delete grace period to users, but **the backend implements neither**. Either build them before launch or remove the promises.

Also note (National Health Act / HPCSA): clinical records generally must be *retained* for minimum periods (HPCSA guidance: typically 6 years from last entry; for minors, until age 21). This **constrains** the POPIA "delete on request" right — the retention policy must reconcile the two. No retention schedule is implemented in code.

12. Existing legal copy already published (your drafting starting point)

12.1 PediCheck (`src/apps/pedichack/src/app/{privacy,terms,contact}/page.tsx`)

Self-labelled **placeholders** ("full POPIA-compliant notice in progress"), but they make **load-bearing factual disclosures** you must honour and keep consistent:

- Operated by "**Atlantic Children's Practice in Cape Town**"; contact hello@pedichack.co.za.
- Collects waitlist (email, WhatsApp, child age range) and contact/feature (email, message).
- "We never sell your information and never share it with third parties for marketing."
- **Explicitly discloses** Google Workspace / Google Sheets storage, processing "outside South Africa," and names it a **"cross-border transfer... under POPIA Section 72,"** stored "only with your explicit consent."
- Terms: "PediCheck is not yet a medical service," "does not establish a doctor-patient relationship," "not a diagnosis," governing law **South Africa**.

12.2 Main web app (`src/apps/web/src/content/legal/{en,af,de}/*.md` , served via `/legal/{slug}`)

Real but **generic SaaS-template** documents (locales: full `en` , partial `af` / `de` ; `{{CURRENT_DATE}}` auto-stamps "last updated"):

- **Real-ish:** `privacy-policy.md` , `terms-of-service.md` , `cookie-policy.md` , `eula.md` . Governing law SA. Contact legal@raisingatlantic.com.
 - ⚠️ The web `privacy-policy.md` is generic — it **does not mention POPIA, Google Sheets, Neon, Sentry, or cross-border transfer**, and it says data is used for **"marketing and promotional purposes."**
 - ⚠️ `cookie-policy.md` claims **"we may use Google Analytics"** — **no analytics is actually deployed** (see §13). Fix the inconsistency.
- **Thin stubs** ("Full content will be provided following legal review"): `disclaimer.md` , `acceptable-use-policy.md` , `clinician-service-agreement.md` , `master-services-agreement.md` , `data-processing-agreement.md` , `data-retention-policy.md` , `information-security-policy.md` , `incident-response-policy.md` (references **POPIA s22** breach notification), `staff-acceptable-use-policy.md` .
- The web footer links only `/legal/privacy-policy` , `/legal/terms-of-service` , `/legal/eula` .

12.3 Marketing claims that the legal documents must not contradict (over-claim risk)

These public statements create exposure under POPIA (Condition 6 openness) and the **Consumer Protection Act** (no misleading claims). Several are **not yet true in code**:

- Web pricing/FAQ: **"fully compliant with POPIA," "all medical data is encrypted at rest and in transit," "bank-grade encryption," "end-to-end encryption," "secure, immutable ledger," "100% Encrypted Data" badge, "securely backed up in the cloud," "audit-ready."** → Reality: **no field-level encryption; no CMEK; auth/RBAC not enforced; data currently offshore on Neon.**
- PediCheck: **"POPIA-compliant, your data stays yours,"** "every pathway clinically reviewed," paid WhatsApp paediatrician line ("ACP Priority," R1,250/mo) with emergency disclaimer.
- PediCheck waitlist counter ("X of 200 founding families") is a **cosmetic localStorage figure starting at 134**, not a real signup count — do not cite it in any representation.

Action: either soften these claims to match the build, or finish the controls before the claims go live. "Fully POPIA compliant" should not appear anywhere until the §8/§9/§11 gaps are closed.

13. Cookies & tracking

- **No cookie-consent banner / CMP exists** in any app — yet the web cookie policy promises cookie controls.
- **No analytics/tracking is actually deployed** (no GA/GTM, Mixpanel, Segment, PostHog, Meta Pixel, Plausible, Vercel Analytics) — despite the cookie policy naming Google Analytics.
- **Cookies actually set:** one first-party functional cookie (sidebar_state UI preference). No tracking cookies.
- **Sentry session replay** is active on web when a DSN is set (maskAllText , blockAllMedia on) — a processor to disclose if enabled.
- **localStorage / AsyncStorage:** PediCheck stores non-PII UI state (waitlist counter, vote dedup map). Web mock stores user records (incl. names/emails) — dev only. **Mobile stores the auth token + user profile in unencrypted AsyncStorage (not SecureStore)** — flag.

Action: the Cookie Policy should describe only what is real (one functional cookie + Sentry if enabled), add a consent mechanism if/when analytics is introduced, and stop naming Google Analytics until it exists.

14. Mobile-specific (app-store privacy)

- **No device permissions are declared** in app.json (no camera/location/notifications/photo/biometric usage strings). Push notifications are a phase-8 TODO (will capture an Expo push token).
 - Collects the full child health record + parent profile (name, phone, language).
 - Has the parental-consent modal and POPIA-rights UI described in §9/§11 (local-only today).
 - **Action:** before store submission, you will need an Apple **App Privacy ("nutrition label")** and Google **Data Safety** declaration consistent with this inventory, plus a public privacy-policy URL linked from inside the app (currently no policy/terms link exists in the mobile UI).
-

15. Applicable South African legal framework (context for the drafter)

Beyond POPIA, a children's healthtech platform should consider:

- **POPIA (Act 4 of 2013)** — the 8 conditions (Accountability, Processing Limitation, Purpose Specification, Further Processing Limitation, Information Quality, **Openness**, **Security Safeguards**, **Data Subject Participation**); **s26–27** special personal information (health); **s34–35** children; **s69** direct marketing; **s72** cross-border; **s22** breach notification; Information Officer registration with the **Information Regulator**.
- **Children's Act 38 of 2005** — definition of a child (under 18), guardianship/consent; note children 12+ can consent to certain medical treatment, which may matter for older minors.
- **National Health Act 61 of 2003 + HPCSA ethical guidelines** — health-record confidentiality, who may access records, and **minimum retention periods** (which constrain the POPIA erasure right).
- **Electronic Communications and Transactions Act 25 of 2002 (ECTA)** — online contracting, electronic signatures, and **s43 mandatory e-commerce disclosures** (relevant once payments go live).
- **Consumer Protection Act 68 of 2008 (CPA)** — applies to consumer subscriptions; **no misleading claims** (see §12.3); cooling-off and fair-terms rules for the paid plans.
- (If marketing emails/SMS:) POPIA s69 + CPA direct-marketing rules (opt-in / opt-out).

The drafter should confirm whether the controller is a **registered medical practice** (which pulls in NHA/ HPCSA obligations directly) vs. a **technology operator** (POPIA operator agreement model) — see §1.

16. Code & infrastructure changes required for genuine compliance

Prioritised. "Blocker" = must exist before the platform can lawfully process real children's health data and before "POPIA compliant" can be claimed.

Blockers (do before any real patient data / before launch claims)

1. **Implement real authentication** — credential storage with hashing (argon2/bcrypt), JWT issuance + verification, refresh tokens, ideally MFA for clinicians/admins. Replace the no-op JwtAuthGuard .

2. **Make RoLesGuard fail closed** and add `@UseGuards` + `@Roles` to every non-public controller (especially `users` , `system-logs` , `verifications` , `children`).
3. **Enforce tenant isolation server-side** — derive tenant context from the authenticated user, never from a client query param; filter every clinical query by it.
4. **Build a server-side parental-consent record** — versioned, timestamped, withdrawable, audited — and gate all child-record creation on it across API/web/mobile. Add age handling.
5. **Complete the data-residency migration** — move the clinical DB from Neon (EU/US) to Cloud SQL `africa-south1` ; enable `deletion_protection = true` for prod; deploy the committed GCP Terraform.
6. **Stop persisting/transmitting PII unredacted** — remove lead email/name from `system_logs` ; stop sending raw DTOs to Sentry; redact before any off-SA processor.

High priority (before public launch / store submission)

7. **Implement DSAR + erasure + soft-delete-with-30-day-grace** to match the promises the mobile UI already makes; add the scheduled hard-delete job and `deletedAt` columns. Reconcile with NHA retention minimums.
8. **Persist & validate HPCSA/SANC numbers** (regex per official format) and build the clinician approve/reject verification workflow (close the `PENDING_ASSESSMENT` loop).
9. **Field-level encryption (KMS) for SPI** — at minimum `medical_conditions` , free-text clinical notes , `report.content` , and HPCSA/SANC numbers; configure CMEK on storage.
10. **Sign operator agreements / DPAs / SCCs** for every processor in §6 (Google, Neon-or-Cloud SQL, Vercel, Sentry, and any email/SMS/payment provider) and disclose sub-processors.
11. **Reconcile the controller identity** (§1) and appoint + register the **Information Officer**.

Medium priority (consistency / hygiene)

12. **Reconcile marketing claims with reality** (§12.3) — soften or substantiate "fully POPIA compliant," "bank-grade / end-to-end / 100% encrypted," "immutable ledger."
13. **Unify legal copy** across PediCheck and the web app (one entity, one set of contact addresses, one cross-border disclosure) and replace the stub `/legal/*` documents.
14. **Add consent capture** to the web lead + contact forms (match PediCheck); make the web contact form actually transmit (it is a `console.log` no-op today) or remove its implied promise.
15. **Cookie policy honesty** — remove the Google Analytics claim until deployed; add a CMP before any analytics/marketing cookies; document the one functional cookie + Sentry replay.
16. **Mobile hardening** — move auth token to SecureStore; add in-app privacy/terms links; prepare Apple/Google data-safety declarations.
17. **Implement the application audit log** (login/logout/role change/record access) for s19/accountability.

17. Facts the legal drafter must obtain from the business (not derivable from code)

- The **registered legal entity / responsible party** name, registration number, and registered address.
 - Relationship between **Raising Atlantic** and **Atlantic Children's Practice** (controller vs operator; who holds the clinical records).
 - The appointed **Information Officer** (and any deputies) for Regulator registration.
 - Confirmed **contact channel** for data-subject requests (one address, not two).
 - **Retention schedule** per data category, reconciled with NHA/HPCSA minimums.
 - **Lawful basis** chosen for each processing purpose (consent vs contract vs legitimate interest vs s27 health-professional ground).
 - Final choices for **payments provider**, **email/SMS provider**, and whether **Gemini AI** features will ship (each adds a processor + possible s72 transfer).
 - Whether **PediCheck** is a separate product/brand with its own controller, and its go-live date claims ("Launching September 2026").
 - Confirmation of the **actual live stack at signing date** (Neon-or-Cloud SQL; Vercel-or-Cloud Run; Sentry on/off) — the s72 disclosure depends on it.
-

18. File reference index (for engineers closing the gaps)

Topic	Key paths
Data model (entities)	src/apps/api/src/**/**/*.model.ts ; migration src/apps/api/db/migrations/1777901196470-InitialSchema.ts ; shared types src/pkgs/types/src/
Auth/guards (stubs)	src/apps/api/src/common/guards/{jwt-auth.guard.ts,roles.guard.ts} ; src/apps/api/src/users/constants.ts
Mock auth	src/apps/web/src/lib/auth.ts ; src/apps/mobile/auth/AuthContext.tsx , src/apps/mobile/lib/api/fixture-jwt.ts
Consent (mobile)	src/apps/mobile/components/children/ParentalConsentModal.tsx ; ProfileScreenParent.tsx (POPIA requests)
Lead / feature-request flows	src/apps/api/src/{leads,feature-requests}/ ; src/apps/pedichack/src/app/api/{leads,feature-requests}/ ; src/apps/pedichack/src/lib/appsScript.ts
Google Sheets (API path)	src/apps/api/src/common/google-sheets/google-sheets.service.ts
Logging / redaction	src/apps/api/src/common/logging/{redact-paths.ts,logger.config.ts} ; src/core/notifications/redact.ts
PII leak paths	src/apps/api/src/leads/leads.service.ts ; src/apps/api/src/{users,tenants,examples}.service.ts (Sentry DTOs)
Sentry / telemetry	src/apps/api/src/instrumentation.ts ; src/apps/web/sentry.*.config.ts ; src/apps/mobile/lib/sentry.ts
DB connection / residency	src/apps/api/db/data-source.ts ; src/apps/api/src/app.module.ts ; src/apps/api/.env.example
Existing legal copy	src/apps/web/src/content/legal/{en,af,de}/*.md ; src/apps/pedichack/src/app/{privacy,terms,contact}/page.tsx
Marketing claims	src/apps/web/src/components/landing/pricing/{PricingFAQ,PricingBusinessClinic}.tsx ; src/apps/pedichack/src/components/landing/{CredibilitySection,PlansSection}.tsx
Infra / residency / encryption	infra/modules/cloud-sql-postgres/ , infra/bootstrap/main.tf , infra/modules/{log-sink,secret,workload-identity}/ , infra/envs/{dev,staging,prod}/
Decisions already made	docs/adr/0001-hosting.md , 0002-payments.md , 0003-app-security-baseline.md , 0004-slos.md
Go-live / compliance tracking	docs/GO_LIVE/{DEV,COMPLIANCE,LEGAL}.md , TODO_GCP.md , docs/VERCEL_PORTABILITY.md

This is an engineering-derived factual reference, not legal advice. The figures, claims, and "current vs. planned" distinctions must be re-verified at the date the legal documents are finalised, because the stack is actively changing.